VIT Vidyalankar Institute of Technology Accredited A+ by NAAC	Vidyalankar Institute Of Technology

Semester	B.E. Semester VII
Subject	WAS
Subject Professor In-charge	Prof Rakshad Sood

Student Name	Chirag Sharma
Roll Number	24101C2007
Assignment No	**07**
Assignment Title	**XSS**
Description	**1. Aim** To detect and exploit Cross-Site Scripting (XSS) vulnerabilities in a web application using DVWA (Damn Vulnerable Web Application).
Procedure	**2. Theory** Cross-Site Scripting (XSS) is a web security vulnerability that allows attackers to inject malicious JavaScript code into web pages viewed by other users. When a vulnerable application fails to properly validate or encode user input, injected scripts may execute in the victim's browser. **Types of XSS** 1. Reflected XSS: Malicious script is reflected immediately in the server response. 2. Stored XSS: Malicious script is stored in the database and executed whenever the affected page is accessed. 3. DOM-based XSS: Vulnerability occurs due to insecure client-side JavaScript handling of user input. **Requirements** • DVWA (Damn Vulnerable Web Application) • Ubuntu / Linux • Apache Server • Web Browser • Burp Suite (Optional) **3. Installation using Ubuntu (WSL)** **Step 3:**

1. **Download DVWA**

cd /var/www/html

sudo git clone https://github.com/digininja/DVWA.git

```
Cloning into 'DVWA'...
remote: Enumerating objects: 5805, done.
remote: Counting objects: 100% (24/24), done.
remote: Compressing objects: 100% (15/15), done.
remote: Total 5805 (delta 13), reused 9 (delta 9), pack-reused 5781 (from 3)
Receiving objects: 100% (5805/5805), 2.94 MiB | 5.59 MiB/s, done.
Resolving deltas: 100% (2874/2874), done.
```

Step 4: Configure DVWA

cd DVWA/config

sudo cp config.inc.php.dist config.inc.php

Open the configuration:

sudo nano config.inc.php

Find these lines:

$_DVWA['db_user'] = 'dvwa';

$_DVWA['db_password'] = 'p@ssw0rd';

```
#   Please use a database dedicated to DVWA.
#
# If you are using MariaDB then you cannot use root, you must use create a dedicated DVWA user.
#   See README.md for more information on this.
$_DVWA = array();
$_DVWA[ 'db_server' ]   = getenv('DB_SERVER') ?: '127.0.0.1';
$_DVWA[ 'db_database' ] = getenv('DB_DATABASE') ?: 'dvwa';
$_DVWA[ 'db_user' ]     = getenv('DB_USER') ?: 'dvwa';
$_DVWA[ 'db_password' ] = getenv('DB_PASSWORD') ?: 'p@ssw0rd';
$_DVWA[ 'db_port']      = getenv('DB_PORT') ?: '3306';

# ReCAPTCHA settings
#   Used for the 'Insecure CAPTCHA' module
#   You'll need to generate your own keys at: https://www.google.com/recaptcha/admin
$_DVWA[ 'recaptcha_public_key' ]  = getenv('RECAPTCHA_PUBLIC_KEY') ?: '';
$_DVWA[ 'recaptcha_private_key' ] = getenv('RECAPTCHA_PRIVATE_KEY') ?: '';

# Default security level
#   Default value for the security level with each session.
#   The default is 'impossible'. You may wish to set this to either 'low', 'medium', 'high' or impossible'.
$_DVWA[ 'default_security_level' ] = getenv('DEFAULT_SECURITY_LEVEL') ?: 'impossible';

# Default locale
```

Step 5: Open DVWA

Open your browser and visit:

DVWA Setup Page

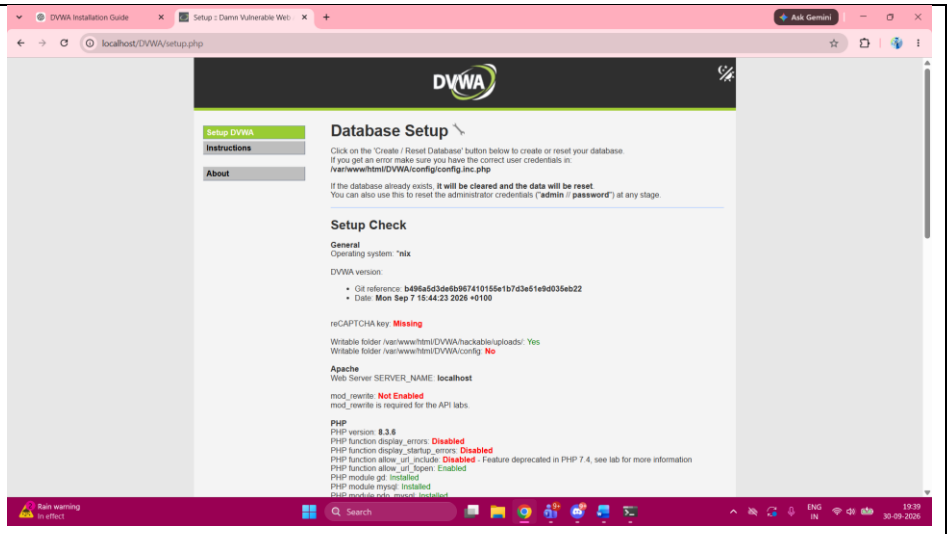
http://localhost/DVWA/setup.php

Open DVWA Setup

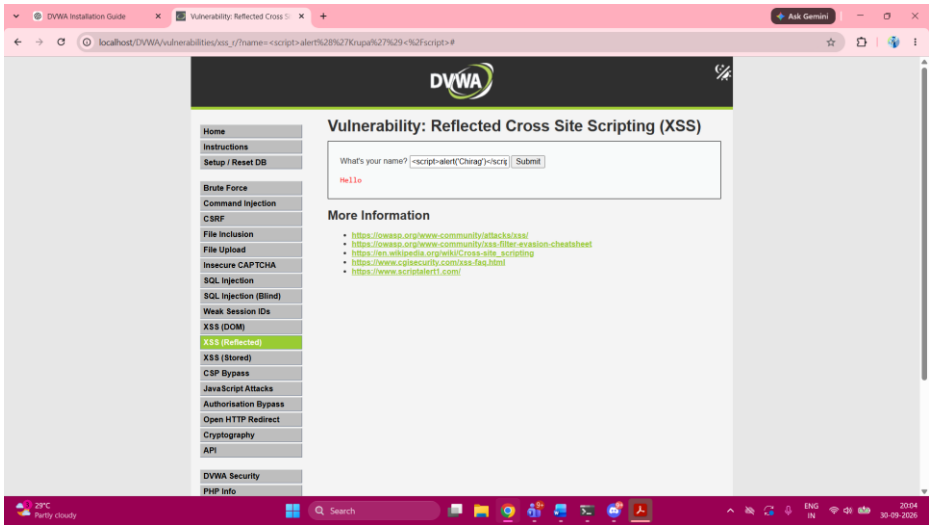
Click Create / Reset Database.

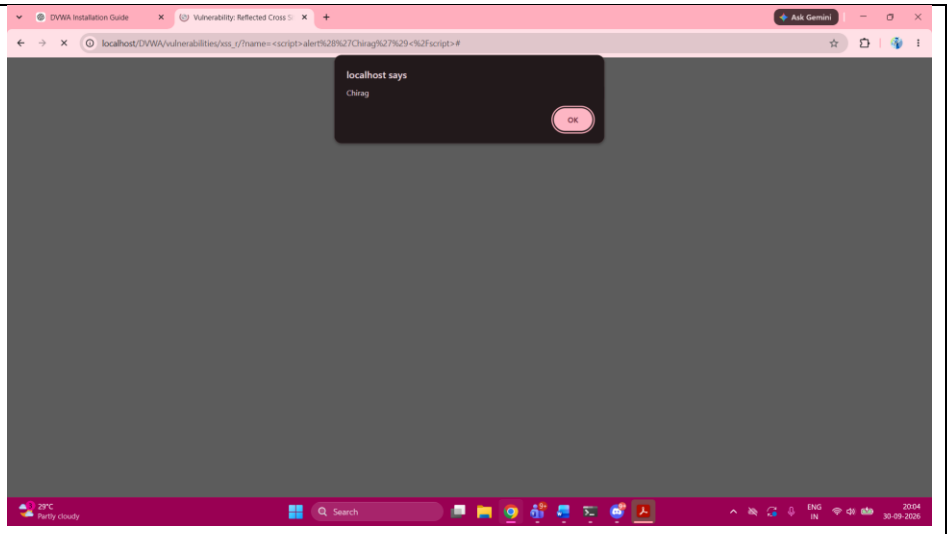
Then go to:

http://localhost/DVWA/login.php



Step 3: Navigate to DVWA Security and set the security level to Low.
Step 4: Select XSS (Reflected) from the left menu.
Step 5: Enter the following payload in the input field:
<script>alert('XSS Vulnerability')</script>



<table>
<tr>
<td></td>
<td>


6. Prevention Techniques

Implement proper input validation.
Use output encoding.
Sanitize untrusted HTML input.
Use Content Security Policy (CSP).
Avoid unsafe JavaScript functions such as innerHTML when handling untrusted input.
Use secure frameworks and libraries.

</td>
</tr>
<tr>
<td>Conclusion</td>
<td>Successfully studied and demonstrated Cross-Site Scripting (XSS) vulnerabilities using DVWA. Identified and exploited Reflected and Stored XSS by injecting JavaScript payloads into vulnerable input fields. Understood how improper input validation and output encoding can allow malicious scripts to execute in a user's browser and learned various techniques to prevent XSS attacks.</td>
</tr>
</table>